

Threat Modeling with AI

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 18: AI Security Use Cases

1. Why Traditional Threat Modeling Breaks Down

Microsoft introduced STRIDE in 1999 — Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — and it remains one of the most widely cited threat categorization frameworks in security architecture. The problem was never the framework. The problem was execution.

In practice, threat modeling sessions are conducted by a small group of senior security architects working from architecture diagrams that may already be months out of date. Developers have added microservices since those diagrams were drawn. Cloud resources have proliferated through self-service portals. Shadow IT has accumulated in corners the architecture review never reached. The result is a threat model that is simultaneously incomplete — missing recent changes — and expensive — requiring expert hours that cannot scale to the pace of modern system evolution.

A threat model produced at initial design becomes a historical artifact within weeks. AI-assisted threat modeling directly addresses both the completeness problem (by discovering architecture automatically) and the scalability problem (by applying threat frameworks in parallel across every component, not just the ones human reviewers get to before the workshop ends).

Core Limitation: Threat models fail not because the frameworks are wrong, but because manual execution cannot keep pace with system change. AI solves the maintenance and scale problems, not the framework problem.

2. What AI-Assisted Threat Modeling Platforms Do

AI-assisted threat modeling platforms ingest architecture information — infrastructure-as-code files, API specifications, deployment diagrams, cloud configuration exports — and automatically generate threat assessments covering the attack surface, probable threat actors, applicable MITRE ATT&CK techniques, and recommended controls.

Three platforms appear frequently in practitioner discussions and are worth knowing by name:

- IriusRisk — threat modeling platform with a library of predefined component threat libraries; integrates with Jira for work item tracking and has added an LLM-specific threat model template.
- Threagile — open-source threat modeling as code; takes YAML infrastructure definitions and produces HTML/PDF threat reports with risk ratings.
- Microsoft Threat Modeling Tool with AI extensions — Microsoft's established tool updated with AI-assisted threat suggestion and ATT&CK mapping.

The key qualification that exam questions will test: AI-generated threat models are comprehensive starting points, not finished products. They capture breadth well — systematically applying threat categories to every identified component. They miss organizational context: the fact that this API

endpoint serves VIP customers who will publicly complain about downtime, or that this database contains data the company's CEO considers a strategic asset. Human review adds that context to AI-generated breadth.

3. Automated Architecture Discovery: Modeling What Is, Not What Was Designed

The single most common reason threat models become inaccurate quickly is that their input — the architecture diagram — diverges from the actual deployed environment. Cloud self-service provisioning allows developers to spin up new services, databases, and integrations without waiting for an architecture review. A threat model based on a six-month-old diagram is modeling a system that no longer exists in that form.

AI-assisted platforms solve this by integrating directly with cloud provider APIs to discover and diagram the actual deployed architecture:

- AWS Config — continuously records the configuration of AWS resources and their relationships; feeds a live architecture view rather than a manually maintained diagram.
- Azure Resource Graph — enables querying of Azure resources across subscriptions; surfaces the actual deployed topology.
- GCP Asset Inventory — similar capability for Google Cloud environments.
- Wiz — specifically builds a security graph from live cloud environment discovery, then applies risk analysis to the actual topology including attack path identification.

When the threat model's input is derived from the live environment rather than a manually updated diagram, it remains accurate as the environment changes — enabling continuous threat modeling rather than point-in-time assessments.

4. STRIDE Applied Systematically at Scale

System Component	STRIDE Category	Specific Threat Example
Public API endpoint	Spoofing	Authentication bypass via weak JWT validation
Public API endpoint	Tampering	Parameter injection altering request logic
Public API endpoint	Repudiation	Insufficient logging prevents attribution
Public API endpoint	Denial of Service	No rate limiting enables request flooding
Backend database	Information Disclosure	SQL injection exposes customer records
Backend database	Elevation of Privilege	Misconfigured permissions allow schema access
Service-to-service calls	Tampering	MITM attack in shared network segment
Admin console	Elevation of Privilege	Broken access control exposes admin functions

A human team applying STRIDE manually might cover the most critical components in a day-long workshop. AI applies this analysis to every component in the architecture in parallel, generating a coverage that would take a human team weeks to match. Each finding includes ATT&CK technique references, enabling direct mapping to detection and mitigation controls already in the security tooling.

5. Attack Path Visualization: The Graph That Changes Prioritization

Individual threat findings tell you that a particular component has a particular vulnerability. Attack path visualization shows you how an attacker moves from an external entry point through intermediate systems to reach a critical target. The difference is significant for prioritization.

Orca Security and Wiz both produce attack graph visualizations that map these multi-step paths explicitly. A security team can interact with the graph and ask: if we remediate this specific misconfiguration, how many attack paths to the payment database are eliminated? That question cannot be answered from a list of individual findings — it requires the graph that shows which findings are load-bearing in attacker movement.

Real-World Scenario — B2B SaaS Company Pre-Launch Threat Model (2022): A company modeled their new API-based data integration feature using IriusRisk before launch. The AI identified a path the architecture team missed: the integration API stored service account credentials in environment variables that appeared in the application's debug log. The debug endpoint was accessible to any authenticated user, not just administrators. An attacker authenticating as any customer could retrieve the service account credentials, which had read access to all customer data. The threat model caught this before a single line of code reached production. Fixing it during design took hours; fixing it after a breach would have required incident response, customer notification, and regulatory reporting.

6. NIST Framework Mapping

Framework	Reference	Requirement Addressed by AI Threat Modeling
NIST CSF 2.0	ID.RA-01	Identify vulnerabilities in assets
NIST CSF 2.0	ID.RA-02	Incorporate cyber threat intelligence from sharing organizations
NIST CSF 2.0	ID.RA-03	Identify and prioritize internal and external threats
NIST AI RMF 1.0	MAP 1.1	Map intended and potentially unintended AI system uses
NIST SP 800-30	Risk Assessment	Threat identification as core risk assessment activity
PCI-DSS v4.0	Req 12.3.2	Annual targeted risk assessment requirement
ISO/IEC 42001:2023	Risk Assessment	Risk assessment for AI management systems

Note that NIST AI RMF 1.0 MAP 1.1 requires mapping intended and potentially unintended uses of AI systems — essentially threat modeling applied to the AI itself, not just AI applied to other systems. As organizations deploy AI, they must threat-model the AI, not only use AI for threat modeling.

7. Threat Modeling LLM and AI Systems

As organizations deploy LLMs, chatbots, and AI-augmented workflows, the threat model must extend to those AI systems. Two key resources provide structured frameworks:

- OWASP LLM Top 10 v1.1 (2024) — categorizes primary risk categories for LLM deployments: prompt injection (manipulating model behavior through crafted inputs), insecure output handling (downstream systems consuming LLM output without sanitization), training data poisoning (compromising model behavior at training time), and excessive agency (LLM taking consequential actions beyond intended scope).
- MITRE ATLAS v2.1 — the adversarial ML equivalent of ATT&CK; a structured taxonomy of adversarial techniques targeting ML systems including reconnaissance, evasion, poisoning, and exfiltration of model artifacts.
- IriusRisk LLM Template — applies OWASP LLM Top 10 categories directly within the IriusRisk threat modeling workflow.
- EU AI Act (2024) — for high-risk AI deployments in the EU, systematic threat assessment is a regulatory requirement, not merely best practice.

8. Red Team Validation: Systematic Blind Spots

Experienced red teams consistently find attack paths that comprehensive AI-generated threat models missed. The gaps are not random — they reflect systematic biases in how threat models are constructed:

- Third-party integrations — vendor portals, partner APIs, and supply chain connections are frequently treated as out-of-scope; red teams exploit them as primary entry points.
- Physical security assumptions — threat models assume physical access controls hold; colocation environments and shared hardware undermine this in practice.
- Human factors — social engineering and insider threats are systematically underweighted in technical threat models; red teams execute them successfully even against technically hardened targets.
- Trust boundary erosion — services designed as internal-only often acquire external-facing components during implementation (load balancer endpoints added for debugging, public DNS created for testing) that the original threat model never captured.

The implication: red team exercises should be designed specifically to probe the threat model's blind spots, and gaps discovered should feed back into updated threat models.

9. Continuous Threat Modeling and CI/CD Integration

AI enables continuous threat modeling by connecting to infrastructure-as-code repositories and triggering automated re-assessment when changes are detected. In mature implementations, pull request reviews in GitHub automatically include a threat model delta showing new attack surfaces introduced by the proposed change and controls required.

Each new service added to the Kubernetes cluster, each new API endpoint published, each external integration approved triggers an automated review of the affected threat model components. This transforms threat modeling from a compliance checkpoint into an ongoing engineering quality control

function — one that provides security feedback at the speed of engineering, not the speed of quarterly review cycles.

10. Protecting Threat Model Artifacts

A comprehensive threat model is a detailed attack roadmap. Organizations that store threat model documents in broadly accessible wikis, include them in vendor briefings without careful review, or fail to classify them appropriately are creating information disclosure risk. The thoroughness that makes AI-generated threat models valuable also makes them high-value intelligence for an attacker who obtains them.

Classification Requirement: Threat model documents should be classified at minimum as Internal Confidential. Access should be restricted to security personnel, senior architects, and those who need to act on specific findings. This applies to both the model and its component threat assessments.

Key Terms Glossary

Term	Definition
STRIDE	Threat categorization framework: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — Microsoft, 1999.
Attack path visualization	Graph showing how an attacker can chain vulnerabilities from an entry point to a critical target; produced by tools like Orca Security and Wiz.
IriusRisk	Commercial threat modeling platform with component threat libraries, Jira integration, and an LLM-specific threat model template.
Threagile	Open-source threat modeling tool that takes YAML infrastructure definitions and produces prioritized threat reports.
NIST AI RMF MAP 1.1	AI Risk Management Framework requirement to map intended and unintended uses of AI systems — applying threat modeling to AI deployments.
OWASP LLM Top 10	Framework categorizing LLM-specific risks: prompt injection, insecure output handling, training data poisoning, excessive agency, and others.
MITRE ATLAS	Adversarial ML technique taxonomy; the ATT&CK equivalent for attacks targeting machine learning systems.
AWS Config	AWS service that continuously records resource configurations; used by AI threat modeling platforms to discover actual deployed architectures.
Trust boundary erosion	Pattern where a service designed as internal-only acquires external-facing components during implementation, expanding attack surface beyond the threat model's scope.
ID.RA (NIST CSF 2.0)	Risk Assessment category within the Identify function; covers vulnerability identification, threat intelligence, and threat

Quick Revision Checklist

- STRIDE covers: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.
- AI threat modeling platforms (IriusRisk, Threatgile, Microsoft Threat Modeling Tool) ingest IaC and generate ATT&CK-mapped assessments.
- Automated architecture discovery (AWS Config, Azure Resource Graph, Wiz) solves the diagram-reality divergence problem.
- AI-generated threat models capture breadth; human review adds organizational context — the combination is optimal.
- Attack path visualization (Orca, Wiz) enables impact-based prioritization by showing multi-step attacker movement.
- NIST CSF 2.0 ID.RA-01/02/03 map to threat identification, threat intelligence, and prioritization.
- NIST AI RMF 1.0 MAP 1.1 requires threat modeling of AI systems themselves.
- OWASP LLM Top 10 and MITRE ATLAS v2.1 are the appropriate frameworks for threat modeling LLM deployments.
- Continuous threat modeling connects to IaC repos and triggers re-assessment when architecture changes.
- Threat model documents are sensitive artifacts requiring restricted access control — comprehensive attack maps are intelligence for attackers.

10 Exam-Based MCQs — Threat Modeling with AI

Test yourself after reading. These questions follow the CompTIA SecAI+ style — scenario-based with plausible distractors. Read every explanation including for correct answers.

Q1. *Scenario:* A cloud security architect is implementing AI-assisted threat modeling for a fintech environment with hundreds of engineers who have made changes through multiple deployment pipelines, the cloud console, and Terraform over three years. The most recent architecture diagram is eight months old. Which data source provides the MOST accurate input for AI-assisted threat modeling of a cloud environment that has been in production for three years?

- A) Architecture diagrams produced during initial system design review
- B) Cloud provider APIs (AWS Config, Azure Resource Graph) reflecting the live deployed topology
- C) Developer interviews to reconstruct services added since the last review
- D) The infrastructure-as-code repository without querying the live environment

Answer: B **Explanation:** B is correct because cloud provider APIs reflect the actual deployed environment, capturing every resource regardless of how it was provisioned. A is wrong because initial design diagrams diverge from reality quickly — after three years of changes by hundreds of engineers, they are likely significantly incomplete. C is wrong because developer interviews are time-consuming, error-prone, and incomplete. D is wrong because IaC repositories may not reflect manual changes made through

the cloud console or out-of-band provisioning pipelines.

Q2. An AI-generated threat model for a healthcare SaaS platform returns 280 identified threats. What is the MOST effective next step?

- A) Assign all 280 threats to engineering teams for immediate parallel remediation
- B) Discard the AI output and conduct a manual threat modeling workshop with senior architects
- C) Have security architects review the output and apply organizational context before prioritizing
- D) Filter to the top 10 threats by ATT&CK technique frequency and accept the remainder as residual risk

Answer: C **Explanation:** C is correct because AI-generated threat models capture breadth but miss organizational context — which systems are crown jewels, which threats are already mitigated by existing controls, which patient data subsets carry the highest regulatory risk. Human review applies that context to create an actionable prioritized list. A is wrong because 280 unreviewed threats creates engineering noise and fatigue without proper context. B is wrong because discarding AI output wastes a comprehensive starting point; the optimal model combines AI breadth with human judgment. D is wrong because ATT&CK technique frequency is not a valid proxy for business risk in a healthcare context.

Q3. Which NIST AI RMF 1.0 practice is MOST directly satisfied when a security team applies OWASP LLM Top 10 threat categories to their organization's deployed LLM chatbot?

- A) GOVERN 1.1 — AI risk management policies are documented
- B) MAP 1.1 — Intended and potentially unintended uses of the AI system are mapped
- C) MEASURE 2.5 — AI system performance is evaluated against defined metrics
- D) MANAGE 1.3 — Responses to AI risks are prioritized based on impact

Answer: B **Explanation:** B is correct because MAP 1.1 specifically requires mapping intended and unintended uses of AI systems — this is the NIST AI RMF framing of threat modeling for AI. Applying OWASP LLM Top 10 to identify how the chatbot could be misused (prompt injection, excessive agency) directly satisfies this mapping requirement. A is wrong because GOVERN 1.1 addresses policy documentation, not active threat identification. C is wrong because MEASURE 2.5 addresses performance metrics, not threat identification. D is wrong because MANAGE 1.3 is a response prioritization activity that follows identification.

Q4. Which framework provides the MOST appropriate threat categories for modeling adversarial attacks against an ML-based anomaly detection system?

- A) STRIDE
- B) OWASP Web Application Security Top 10
- C) MITRE ATLAS v2.1
- D) NIST SP 800-53 Control Families

Answer: C **Explanation:** C is correct because MITRE ATLAS v2.1 is specifically designed as a taxonomy of adversarial techniques against ML systems — including model evasion (crafting inputs the model

misclassifies), poisoning (corrupting training data), and model extraction. A is wrong because STRIDE was designed for general IT system components; it does not cover ML-specific adversarial techniques like feature-space evasion or model inversion. B is wrong because OWASP Web Application Top 10 addresses web application vulnerabilities, not ML-system adversarial threats. D is wrong because NIST SP 800-53 is a control catalog, not a threat framework.

Q5. What is the PRIMARY security concern with storing an AI-generated threat model in a broadly accessible internal wiki?

- A) The threat model will become outdated quickly as the system evolves
- B) The comprehensive attack path documentation provides attackers with a roadmap if insider threat or account compromise occurs
- C) Employees without security expertise may misinterpret findings and attempt unauthorized remediation
- D) Compliance auditors may not accept AI-generated threat models as valid risk assessment artifacts

Answer: B **Explanation:** B is correct because a comprehensive threat model explicitly maps attack paths to critical assets — it is valuable intelligence for an attacker who obtains it through insider access or a compromised account. Broad access increases the exposure risk significantly. A is wrong because staleness is a maintenance concern, not a security concern arising from storage location. C is wrong because misinterpretation is a training issue, not a primary security risk. D is wrong because compliance frameworks generally accept systematic threat modeling regardless of AI assistance.

Q6. A security team reviews an attack path visualization from Wiz and identifies that remediating one specific S3 bucket misconfiguration eliminates 47 of 62 attack paths to the customer data store. What concept does this demonstrate?

- A) Vulnerability scoring using CVSS base metrics
- B) Impact-based prioritization enabled by attack path graph analysis
- C) Threat intelligence mapping to MITRE ATT&CK techniques
- D) Continuous threat model refresh triggered by infrastructure changes

Answer: B **Explanation:** B is correct because attack path visualization enables impact-based prioritization by showing how many attacker paths depend on a specific finding. This question cannot be answered from a flat vulnerability list — it requires the graph that reveals which findings are load-bearing for attacker movement. A is wrong because CVSS scores individual vulnerabilities in isolation; they don't show how findings combine in attack chains. C is wrong because ATT&CK mapping categorizes techniques but doesn't model how findings chain together toward targets. D is wrong because continuous refresh is about keeping the model current, not about using path analysis for prioritization.

Q7. Which of the following is the MOST accurate description of what AI-generated threat models capture well versus what they consistently miss?

- A) AI captures organizational context well but misses technical breadth

- B) AI captures technical breadth across all components but misses organizational context about asset criticality and compensating controls
- C) AI captures both breadth and organizational context, making human review unnecessary
- D) AI captures only the OWASP Top 10 categories and misses all other threat types

Answer: B **Explanation:** B is correct because AI platforms excel at comprehensive, systematic application of threat frameworks across every architecture component simultaneously — breadth that humans cannot match manually. What they miss is organizational context: which assets are crown jewels, which threats are already mitigated by existing controls, which business processes make certain risks unacceptable. A is wrong because it reverses the actual strengths — AI captures technical breadth, not organizational context. C is wrong because AI-generated models without human review are comprehensive starting points, not finished products. D is wrong because AI threat modeling applies STRIDE, ATT&CK, and other frameworks well beyond OWASP Top 10.

Q8. A red team reports finding a successful attack path through a vendor portal that was explicitly marked out-of-scope in the organization's threat model. What is the MOST appropriate response?

- A) Update the scope definition to exclude vendor portals from all future security assessments
- B) Update the threat model to include third-party integrations and update scope definitions to ensure vendor portals are covered in future assessments
- C) Escalate to the vendor to request they fix their security posture before the next assessment
- D) Accept the risk because the attack path originated outside the organization's direct control

Answer: B **Explanation:** B is correct because the red team finding reveals a systematic threat model blind spot — third-party integrations are frequently excluded from scope but exploited as entry points. The appropriate response is to update both the threat model and assessment scope to cover these integrations. A is wrong because it would permanently exclude a demonstrated attack vector from future assessments. C is wrong because while vendor remediation may be required, the organization's own threat model gap must also be addressed. D is wrong because an attacker does not respect organizational boundaries of control — attack paths that traverse vendor portals are real operational risks regardless of ownership.

Q9. PCI-DSS v4.0 Requirement 12.3.2 requires annual targeted risk assessments. How do AI-assisted threat modeling platforms BEST support this compliance requirement?

- A) By replacing annual assessments with continuous monitoring, satisfying the intent of the requirement
- B) By generating dated, documented threat assessments with identified risks, applied controls, and residual risk documentation as compliance artifacts
- C) By mapping all findings to PCI-DSS control families, satisfying the specific language of Requirement 12.3.2
- D) By providing real-time ATT&CK technique mapping that demonstrates ongoing threat awareness

Answer: B **Explanation:** B is correct because PCI-DSS requires demonstrable evidence of systematic risk assessment, and AI threat modeling platforms automatically generate dated threat assessments with identified risks, applied controls, and residual risk documentation — exactly the compliance artifacts an

assessor needs. A is wrong because PCI-DSS v4.0 requires annual assessments explicitly; continuous monitoring supplements but does not replace them. C is wrong because the requirement focuses on risk identification and documentation, not ATT&CK/PCI control mapping per se. D is wrong because real-time ATT&CK mapping is valuable but is not by itself the structured risk assessment documentation PCI requires.

Q10. What is the BEST reason to integrate threat modeling tooling with the CI/CD pipeline so that pull requests trigger automated threat model delta assessments?

- A) To satisfy the NIST AI RMF requirement that all AI system changes be reviewed by a dedicated ethics board
- B) To ensure security assessment keeps pace with engineering velocity, identifying new threats at the point of change rather than in quarterly reviews
- C) To generate compliance evidence that demonstrates continuous monitoring for PCI-DSS and SOC 2 purposes
- D) To reduce the need for manual penetration testing by automatically verifying that all code changes are secure

Answer: B **Explanation:** B is correct because the fundamental value of CI/CD-integrated threat modeling is timing — security feedback at the point of change, when it is cheapest to remediate, rather than in quarterly reviews when the code has long since shipped. A is wrong because NIST AI RMF does not require ethics board review of system changes through CI/CD pipelines. C is wrong because while compliance artifacts are a useful byproduct, they are not the primary purpose of CI/CD integration. D is wrong because automated threat model updates identify new threat surfaces but do not replace penetration testing, which validates whether identified threats are actually exploitable.